

Fullstack Development

Authentication / Authorization

Part 5: Web Authentication

What is Web Authentication?

- The **Web Authentication** API (also known as **WebAuthn**) is a specification written by the W3C and FIDO.
 - **W3C** (Web Consortium) is an international community that develops open standards to ensure the long-term growth of the Web.
 - **FIDO** (Fast Identity Online) is an open industry association whose mission is to develop and promote authentication standards that help reduce the world's over-reliance on passwords.

What is Web Authentication?

- The **Web Authn** API uses public-key cryptography (commonly known as **passkeys**) to authenticate users to web applications and services.

Why?

- Passwords are **insecure** and **hard to remember**.
- 2FA (Two-Factor Authentication) is **inconvenient**.
 - It is often a hassle to use a second device or app to generate a code.
- Passkeys are **secure** and "**easy to use**".
 - They are stored on your device and can be used to log in with a single tap or click.
 - They are resistant to phishing attacks because they cannot be shared or stolen like passwords.

History of Web Authentication

- The Web Authentication API was first introduced in 2014 by the FIDO Alliance and the W3C.
- The first version of the specification was published in 2018, and it has since been updated several times to improve security and usability.
- The Web Authentication API is now supported by all major browsers and mobile platforms.

Parties

- The **Relying Party**: a website or application that wants to authenticate a user
- The **Authenticator**: a hardware security key or the user's device
- The **Client/Agent**: the user's browser or operating system that communicates with the Relying Party and the Authenticator
- The **User**: the person trying to authenticate

Authenticator

- The **Authenticator** is a device that can generate and store cryptographic keys, and perform cryptographic operations such as signing and verifying data.
- The Authenticator can be
 - A hardware security key (e.g., YubiKey)
 - A built-in device (e.g., fingerprint scanner, Face ID)
 - A software-based authenticator (e.g., Google Authenticator, Bitwarden).

Side note

- Authenticators are similar to 2FA (Two-Factor Authentication) in that they provide an additional layer of security beyond just a password.
- They combine something you know (e.g., a PIN or password) with something you have (e.g., a hardware security key or your device) to provide two-factor authentication.

How does public-key cryptography work?

- <https://markshope.github.io/public-private-key-demo>
- Notes
 - The authenticator stores a **private key** while the server stores a **public key**.
 - The private key is **never shared** with anyone, including the server (unlike passwords).

Authentication flow with WebAuthn

- [Diagram](#)
- [source](#)

Demo

- `git clone https://github.com/fullstack-69/auth-webauthn.git`

Library

- SimpleWebAuthn
 - Also used in better-auth .